

PAVAN DEVARAJ

@ pavankdevaraj@gmail.com

📞 9886464838

📍 Bengaluru, India 560010

Accomplished Cyber Security Consultant with extensive experience in governance, risk, and compliance (GRC) frameworks, including ISO 27001/27701, NIST 800-53, HIPAA, GDPR, and SOX. Proven track record in designing and implementing robust security architectures and compliance programmes across diverse industries. Expertise in security operations centres (SOC) using SentinelOne and advanced SIEM tools like Qradar, Arcsight, and Splunk. Skilled in vulnerability management with Qualys and Rapid7, as well as endpoint and network security solutions such as CrowdStrike and Sophos. Adept at cloud security management on AWS platforms with IAM, KMS, CloudTrail, and CloudWatch. Notable achievements include leading successful phishing campaigns to enhance security awareness and reducing incident response times by over 30%. Career goal: to leverage comprehensive cybersecurity expertise to drive strategic initiatives that fortify organisational resilience against evolving threats.

EXPERIENCE

03/2024 - Current

Cyber Security Consultant, Yash Technologies, Bengaluru, Karnataka CYBERSECURITY

- Built and tuned **threat detections** mapped to MITRE ATT&CK across SIEM/XDR telemetry (Splunk, QRadar, SentinelOne), improving true-positive rate and reducing noise.
- Led **threat hunting** using hypothesis-driven queries and IOC/TTP pivoting; converted hunt findings into reusable playbooks and new detections.
- Drove **incident response** end-to-end—containment, eradication, recovery—and delivered RCAs with control fixes to prevent recurrence.
- Deployed and operated **EDR** (Sophos, SentinelOne) with isolation, rollback, and behavioural policies; strengthened endpoint hardening and lateral-movement resistance.
- Implemented **vulnerability management** with Rapid7 and Qualys; risk-based prioritization, remediation SLAs, exception governance, and remediation verification.
- Enforced **data security** policies with Secuvy (classification, access reviews, retention, DSR/DSAR workflows); improved audit trails for sensitive datasets.
- Performed **threat modeling** (applications/systems/infrastructure); identified misuse/abuse cases, prioritized risks, and recommended targeted mitigations in SDLC.
- Designed **security awareness** programs on KnowBe4/LMS; delivered role-based content and continuous training in partnership with HR and IT.
- Ran **phishing campaigns** (KnowBe4); crafted realistic scenarios, analyzed click/report ratios, rolled out micro-training, and updated detections to cut repeat clickers.
- Established **AI/GenAI security** guardrails and acceptable-use; conducted AI risk/impact assessments and integrated usage monitoring into existing controls.
- Supported **presales** across EDR/XDR, vulnerability management, IR/IRR, IAM, and cloud; built demos/PoVs and BoMs; coordinated with partners (CrowdStrike, Vulcan, Simbian, Qualys, Microsoft, AWS).

GRC & AUDIT READINESS

- Developed and operationalized **NIST CSF metrics**; led gap and maturity assessments; produced executive dashboards and action plans to uplift controls.
- Prepared organizations for **ISO/IEC 27001** and **GDPR** audits—evidence collection, corrective actions, and closure tracking.
- Authored and maintained **policies, standards, and SOPs**; implemented governance

for policy lifecycle, exceptions, and periodic control testing.

04/2023 - 10/2023

GRC Architect, Tecplix Technologies Private Limited, Bengaluru
GRC / Compliance (Architect)

- Program Architecture: Designed and implemented org-wide GRC programmes; established control libraries mapped to NIST CSF, ISO 27001, ISO 27701, HIPAA, GDPR, and DPDP.
- Risk Management: Defined risk appetite, KRIs, KPIs, and RACI; led enterprise risk assessments, RCSAs; maintained risk registers and risk treatment plans with ownership and due dates.
- ISO 27001 (ISMS): Ran end-to-end certification cycles (SoA, risk treatment, internal audits, management review); ensured surveillance audit readiness, and closed nonconformities.
- ISO 27701 (PIMS): Implemented privacy roles and records management; aligned data inventories, records of processing, and privacy controls to standard requirements.
- HIPAA: Operationalised administrative, technical, and physical safeguards; monitored KPIs; coordinated BAAs and periodic compliance attestations.
- GDPR: Conducted DPIAs and maintained RoPA; operationalised DSAR workflows; implemented privacy-by-design, retention controls, and monitored ongoing compliance.
- **DPDP (India)**: Led enterprise data mapping and privacy impact assessments; implemented consent and data principal rights workflows; aligned policies and notices to DPDP obligations.
- **Third-Party Risk**: Built vendor due diligence and periodic reassessment workflows; managed DPAs, risk findings, exceptions, and remediation tracking with procurement and legal.
- **Policy Lifecycle**: Authored and maintained policies, standards, and SOPs; implemented exceptions governance, version control, and company-wide policy attestations.
- Compliance Monitoring and Reporting: Implemented metrics and automated reporting; leveraged Splunk, ArcSight, and QRadar for SIEM-driven evidence and control monitoring.
- **Vulnerability/Risk Inputs**: Used **Qualys** and **Rapid7** outputs to drive risk scoring, remediation SLAs, and executive heatmaps; linked remediation to risk-reduction targets.
- Audit Readiness: Coordinated internal and external audits; curated evidence, mapped controls, tracked CAPA through closure, and produced board-level status and maturity reports.
- **Privacy & Data Governance**: Enforced classification, access governance, retention, and deletion; aligned DSR/DSAR processes with legal and business stakeholders.
- Training and Awareness: Delivered role-based security and compliance training (LMS/KnowBe4); tracked completion and effectiveness; embedded compliance checkpoints in onboarding.
- Regulatory Intelligence: Monitored regulatory and standard updates; refreshed control libraries and procedures; briefed leadership on impacts and remediation actions.
- Metrics & Maturity: Built NIST CSF maturity models and scorecards; reported KRIs, KPIs, risk-posture trends, and remediation velocity to executives.

02/2021 - 04/2023

Information Technology Manager(Network Security), Concentrix Daksh Services India Private Limited, Bangalore

- Reviewed high-risk project designs and embedded network controls early (segmentation, encryption, zero-trust patterns).
- Defined network security requirements and implementation guidance for PMs, BAs, architects, and support teams.
- Assessed and uplifted enterprise control posture across on-prem/cloud networks,

edge, and remote access.

- Ensured compliance mapping for **NIST 800-53/171, ISO 27001, SOX, PCI DSS, HIPAA** within network architectures.
- Analyzed **VA/PT** findings for network/infra; prioritized remediation, documented risk, and drove closure/acceptance.
- Documented deviations from standards, quantified risk levels, and recommended mitigations for operational & non-operational scenarios.
- Maintained asset and data-flow inventories; contributed to incident playbooks for network events (DDoS, exfiltration, privilege abuse).
- Led engineer-focused awareness on secure configs (hardening, patching, least privilege); improved baseline hygiene.
- Reduced cost and compliance exposure via configuration/license audits and rationalization of unused tooling.
- Performed network security assessments (firewalls, VPN, IDS/IPS, WAF, NAC; cloud controls like security groups/NACLs) and delivered actionable hardening plans.

05/2019 - 01/2021

Information Security Engineer (Network Security), Conduent Pvt Ltd, Bangalore

- **Designed and implemented comprehensive cybersecurity systems**, integrating advanced threat detection and prevention measures for real-time monitoring and alerting, which improved incident response times by over 30%.
- **Led the architecture and deployment of network security solutions**, including firewalls, VPNs, and intrusion detection systems (IDS), ensuring robust perimeter defenses and secure remote access across the enterprise.
- **Implemented layered security controls** utilizing multi-factor authentication (MFA), role-based access, and network segmentation, thereby reducing unauthorized access incidents by 20%.
- **Integrated endpoint security solutions** to enhance endpoint monitoring, threat detection, and response capabilities, achieving full visibility into potential threats and minimizing endpoint-related risks.
- **Optimized system performance** while maintaining stringent security protocols, ensuring secure network operations that support high availability and business continuity.
- **Evaluated and enhanced the security architecture** of high-risk projects, introducing scalable solutions that align with industry best practices and regulatory requirements.
- **Executed vulnerability assessments and penetration testing (VA-PT)** across the network infrastructure, using industry-leading tools, to proactively identify vulnerabilities and secure critical assets.
- **Developed customized incident response procedures**, reducing average time to containment and recovery for high-risk incidents by 40%.
- Conducted comprehensive reviews of high-risk projects, using GRC ServiceNow for KPI monitoring and security compliance
- Enhanced Information Security Controls using parallel SIEM solutions like Splunk, Arcsight, and Qradar
- Documented deviations from standards, estimated risk levels, and recommended mitigation using GRC ServiceNow
- Reviewed VA-PT results, identified risks, and recommended remediation actions with Qualys and Rapid7

06/2018 - 05/2019

Senior Risk Consultant , Ernst & Young PVT. LTD, Bangalore

- Identified strategic corporate issues and associated risks.
- Established mission, policies, procedures, standards, and guidelines for the internal audit function.
- Managed the corporate quality management system.
- Managed Global SOX engagements for banking organizations, overseeing SOC Type 1

and Type 2 audits and ensuring alignment with Sarbanes-Oxley (SOX) compliance processes.

- Conducted investigations into fraud and unethical practices.
- Provided expert guidance on Compliance and controls to financial service clients(**Well Fargo**), specifically focusing on SOX requirements.
- Fostered strong client relationships.
- Maintained communication with management.
- Cultivated business development opportunities.
- Established collaborative relationships with team members.

09/2016 - 05/2018

Cloud Security Architect, Mindtree PVT. LTD, Bangalore

Experienced in IT Governance, Risk, and Compliance, with expertise in assessing internal controls, mitigating compliance vulnerabilities, and ensuring data privacy. Proficient in Endpoint Security, Network Security, SIEM, SOC, Vulnerability Management, and SOAR platforms. Deep understanding of regulatory requirements and industry best practices.

Key Responsibilities and Achievements:

- Applied relevant regulations and guidelines to proactively manage risk and ensure compliance.
- Developed, maintained, and audited security documentation, aligning with regulatory requirements and security objectives.
- Monitored and enhanced internal controls, identifying areas for improvement.
- Collaborated with stakeholders to formulate and execute corrective action plans.
- Leveraged AWS Key Management Service (KMS) for robust encryption of sensitive data.
- Utilized AWS Identity and Access Management (IAM) for fine-grained access control.
- Integrated AWS CloudTrail for comprehensive audit trail monitoring and analysis.
- Implemented AWS CloudWatch for real-time monitoring, logging, and alerting of AWS resources.
- Utilized AWS Config to assess, audit, and evaluate the configuration of AWS resources for compliance.
- Expertise in Endpoint Security, Network Security, SIEM, SOC, and advanced security tools.
- Reviewed and enhanced Information Security and Data Privacy Policies and Procedures.

08/2010 - 09/2016

Risk and Security Manager, IBM INDIA PVT. LTD, Bangalore
Information Security (Banking Sector: State Street, JP Morgan)

- Led the implementation of a health checking subsystem project, enhancing overall security.
- Initiated annual Security Awareness Letter campaigns to educate stakeholders.
- Managed health check suppression, optimizing security operations.
- Developed a comprehensive data classification framework.
- Effectively managed health check findings on servers, ensuring timely resolution.
- Spearheaded change management for security-related changes.
- Led security incident management efforts, ensuring swift responses.
- Orchestrated bi-annual meetings for firewall and router rule revalidation.
- Ensured compliance with security requirements documents in the Information Security Policy.
- Conducted vulnerability scanning and security health checks on in-scope servers and network devices.
- Supported InfoSec assessments and controls demonstrations for compliance.
- Translated business requirements into control objectives, designed security controls,

- and implemented them within a security management cycle.
- Conducted independent security controls reviews.

SKILLS

Governance, Risk & Compliance (GRC) - ServiceNow
GRC, ISO 27001/27701, NIST
800-53, HIPAA, GDPR, SOX,
DPDP
Security Operations (SOC) -
SentinelOne, Qradar, Arcsight,
Splunk
Vulnerability Management -
Qualys, Rapid7, Nessus

Endpoint & Network Security -
CrowdStrike, Sophos, FireEye,
Symantec, Carbon Black
Cloud Security - AWS IAM, KMS,
Config, CloudTrail, CloudWatch
Awareness & Training -
KnowBe4, Security Awareness
Campaigns

Incident & Risk Management -
VA/PT Reviews, RCA, Risk
Register, Compliance Tracking
Data Protection - Secuvy,
Endpoint Protector, Privacy
Impact Assessments (PIAs)

CERTIFICATIONS

2015-02
Information Security Management System ISO 27001:2013: 19011:2011 from TUV SUD
2015-02
COBIT 5 Foundations, from APMG
2017-02
Certified Payment Card Industry Security Implementer 3.2 from SISA
2017-02
Privacy and EU GDPR Practitioner

EDUCATION

2010 **Bachelor of Engineering, Electrical, Electronics, And Communications Engineering**
Sir M. Visvesvaraya Institute of Technology, Bengaluru

AFFILIATIONS

- GRC Committee Participation, Policy Development, Risk based Audits, Risk Assessments, Threat Hunting, Training and Education and Vendor Risk Management